

EST 워게임 문제 워크스루

난이도 재조정 반영본 · 문제별 페이지 분리

난이도 조정 요약

번호	문제	분류	난이도	전과	조정 판단
1	세션 그림자	쿠키 변조	초급	150	쿠키 값 변경만으로 확인 가능한 입문형 문제라 유지.
2	반사 게시판 검색	DOM XSS	초급	180	innerHTML과 이벤트 핸들러 단서가 명확해서 초급으로 하향.
3	영상 보급창	Path Traversal	중급	260	allowed.png/ 디렉터리 단서를 노출했으므로 중급으로 하향.
4	코인 제국 보급 작전	Client Trust	중급	260	브라우저 저장소 조작으로 풀 수 있어 300점에서 하향.
5	작전 보고서 열람소	IDOR	중급	280	URL 파라미터 관찰과 번호 추측 문제라 중급으로 조정.
6	비문 공지 검색소	Boolean Blind SQL Injection	중상급	340	직접 출력 없이 참/거짓 반응으로 자동화 추출이 필요해 상향.
7	네트워크 진단	Command Injection	중상급	350	명령 구분자와 서버 파일 경로 이해가 필요해 유지.
8	내부 보급망 점검기	SSRF	중상급	375	localhost 기준 차이를 이해해야 하므로 유지.
9	관리관 메모 연쇄	Stored XSS	고급	400	저장형 XSS와 관리관 API 연계가 필요해 유지.
10	전송 파일 업로드	File Upload	고급	450	웹셸 업로드와 서버 실행 맥락이 필요해 최고 난이도 유지.

1. 세션 그림자

문제 ID	session-shadow
분류 / 난이도	쿠키 변조 / 초급
전과	150
FLAG	FLAG{cookie_role_admin_shadow}

목표

shadow_role 쿠키를 admin으로 바꿔 출입 판정을 통과한다.

풀이 절차

- 1 문제 페이지에서 현재 출입 판정이 limited인지 확인한다.
- 2 개발자 도구의 Application 또는 Storage에서 shadow_role 쿠키를 찾는다.
- 3 쿠키 값을 admin으로 바꾸고 새로고침한다.
- 4 granted 상태와 FLAG를 확인한다.

핵심 입력

```
document.cookie = "shadow_role=admin; path=/"
```

핵심 포인트

서버가 쿠키 값을 검증 없이 신뢰한다.

2. 반사 게시판 검색

문제 ID	reflected-board
분류 / 난이도	DOM XSS / 초급
전과	180
FLAG	FLAG{dom_xss_reflected_search_alert}

목표

검색 결과 영역에서 alert() 호출을 발생시킨다.

풀이 절차

- 1 검색어가 결과 영역에 그대로 반사되는지 확인한다.
- 2 `<b>test</b>`를 입력해 HTML 해석 여부를 본다.
- 3 script 태그 대신 자동 실행 이벤트를 가진 태그를 사용한다.
- 4 alert() 호출이 감지되면 FLAG가 표시된다.

핵심 입력

```
<img src=x onerror="alert(1)">
```

핵심 포인트

alert 안의 문자열은 중요하지 않고 함수 호출 자체가 조건이다.

3. 영상 보급창

문제 ID	image-vault
분류 / 난이도	Path Traversal / 중급
전과	260
FLAG	FLAG{lz10MXMwOSZrMjBlb2M}

목표

파일명 필터와 실제 경로 해석 차이로 flag.txt를 읽는다.

풀이 절차

- 1 보급창 색인에서 cover.png와 allowed.png/를 확인한다.
- 2 필터가 .png 포함 여부만 검사한다는 점을 확인한다.
- 3 allowed.png/ 디렉터리에서 ../로 한 단계 빠져나온다.
- 4 최종 경로가 flag.txt를 가리키게 만든다.

핵심 입력

```
allowed.png/../flag.txt
```

핵심 포인트

allowed.png는 파일이 아니라 디렉터리 단서다.

4. 코인 제국 보급 작전

문제 ID	idle-empire
분류 / 난이도	Client Trust / 중급
전과	260
FLAG	FLAG{idle_empire_client_trust_bypass}

목표

클라이언트 저장소 또는 최종 보고 요청 값을 조작한다.

풀이 절차

- 1 localStorage에서 idleEmpireSave 값을 확인한다.
- 2 totalEarned가 목표 달성 판단에 쓰이는지 본다.
- 3 totalEarned를 100000000 이상으로 바꾼다.
- 4 claim 요청 후 FLAG를 확인한다.

핵심 입력

```
localStorage.setItem('idleEmpireSave', JSON.stringify({coins:100000000,totalEarned:100000000,playTime:0,levels:{}}))
```

핵심 포인트

중요한 검증을 클라이언트 값에 맡기면 사용자가 결과를 바꿀 수 있다.

5. 작전 보고서 열람소

문제 ID	mission-report
분류 / 난이도	IDOR / 중급
전과	280
FLAG	FLAG{cDgkb2FfdDE5MV9ycjQ}

목표

보고서 번호를 직접 바꿔 비공개 보고서에 접근한다.

풀이 절차

- 1 공개 보고서 목록을 클릭하고 URL의 report 값을 확인한다.
- 2 목록에는 1001~1003만 보이지만 서버가 번호를 직접 받는지 확인한다.
- 3 1004~1007 더미 보고서로 번호 기반 구조를 파악한다.
- 4 report=1008에 접근해 비문 보고서의 FLAG를 확인한다.

핵심 입력

```
http://100.83.178.9/challenges/mission-report.php?report=1008
```

핵심 포인트

객체 ID만 바꿨을 때 권한 검사가 없으면 다른 객체에 접근할 수 있다.

6. 비문 공지 검색소

문제 ID	blind-notice
분류 / 난이도	Boolean Blind SQL Injection / 중상급
전과	340
FLAG	FLAG{boolean_blind_notice_42c7}

목표

검색 결과 존재 여부만으로 FLAG를 한 글자씩 추출한다.

풀이 절차

- 1 다음표를 닫고 OR 조건을 붙여 참/거짓 반응 차이를 만든다.
- 2 SUBSTR(body,위치,1) 조건으로 문자를 하나씩 비교한다.
- 3 응답 문구가 "조건에 맞는 공지가 존재합니다."인지 확인한다.
- 4 반복 요청이 많으므로 스크립트로 자동화한다.

핵심 입력

```
%' OR SUBSTR(body,1,5)='FLAG{' --
```

핵심 포인트

데이터가 출력되지 않아도 Boolean 반응만 있으면 추출 가능하다.

7. 네트워크 진단

문제 ID	net-diagnostics
분류 / 난이도	Command Injection / 중상급
전과	350
FLAG	FLAG{ops_ping_command_injection}

목표

ping 명령 뒤에 추가 명령을 이어 붙여 플래그 파일을 출력한다.

풀이 절차

- 1 정상 IP를 입력해 출력 형태를 확인한다.
- 2 입력값이 ping 명령 뒤에 붙는 구조를 확인한다.
- 3 ; 또는 && 뒤에 cat 명령을 붙인다.
- 4 /tmp/est-net-diagnostics-flag.txt 내용을 출력한다.

핵심 입력

```
127.0.0.1; cat /tmp/est-net-diagnostics-flag.txt
```

핵심 포인트

사용자 입력이 셸 명령 문자열로 조립될 때 발생한다.

8. 내부 보급망 점검기

문제 ID	internal-supply
분류 / 난이도	SSRF / 중상급
전과	375
FLAG	FLAG{ssrf_internal_supply_route}

목표

서버의 대리 조회 기능으로 내부 전용 경로에 접근한다.

풀이 절차

- 1 브라우저에서 직접 internal=flag 접근 시 막히는지 확인한다.
- 2 URL 입력값을 서버가 대신 요청한다는 점을 이용한다.
- 3 127.0.0.1 내부 경로를 대리 조회로 호출한다.
- 4 서버 기준 localhost 요청이므로 내부 전용 FLAG가 출력된다.

핵심 입력

```
http://127.0.0.1/challenges/internal-supply.php?internal=flag
```

핵심 포인트

SSRF에서 127.0.0.1은 사용자 PC가 아니라 요청을 보내는 서버 자신이다.

9. 관리자 메모 연쇄

문제 ID	admin-memo-chain
분류 / 난이도	Stored XSS / 고급
전과	400
FLAG	FLAG{stored_xss_admin_memo_chain}

목표

저장된 메모가 HTML로 실행되게 만들어 관리자 API 호출을 유도한다.

풀이 절차

- 1 메모 본문이 escaping 없이 출력되는지 확인한다.
- 2 자동 요청을 발생시키는 HTML 태그를 메모로 저장한다.
- 3 admin_api=flag 요청을 관리자 검토 흐름에서 처리되게 만든다.
- 4 검토 결과에 기록된 FLAG를 확인한다.

핵심 입력

```

```

핵심 포인트

저장된 페이로드가 나중에 렌더링되며 실행되는 점이 reflected XSS와 다르다.

10. 전송 파일 업로드

문제 ID	upload-dispatch
분류 / 난이도	File Upload / 고급
전과	450
FLAG	FLAG{dispatch_upload_php_execution}

목표

이미지 문자열 검사를 우회해 PHP 파일을 업로드하고 숨은 파일을 읽는다.

풀이 절차

- 1 파일명에 .png를 포함하되 마지막 확장자는 .php로 둔다.
- 2 업로드 후 공개 경로로 접근해 PHP 실행 여부를 확인한다.
- 3 업로드 디렉터리의 .dispatch_flag를 읽는다.
- 4 출력된 FLAG를 제출한다.

핵심 입력

```
파일명: shell.png.php  
내용: <?php echo file_get_contents(__DIR__ . '/.dispatch_flag'); ?>
```

핵심 포인트

파일명 문자열 검사와 웹 서버 실행 판단이 다르면 업로드 우회가 가능하다.